

Withdrawn NIST Technical Series Publication

Warning Notice

The attached publication has been withdrawn (archived), and is provided solely for historical purposes. It may have been superseded by another publication (indicated below).

Withdrawn Publication

Series/Number	NIST Special Publication 800-63B
Title	Digital Identity Guidelines: Authentication and Lifecycle Management
Publication Date(s)	June 2017 (includes updates as of 03-02-2020)
Withdrawal Date	August 1, 2025
Withdrawal Note	NIST SP 800-63B is withdrawn and superseded in its entirety by NIST SP 800-63B-4.

Superseding Publication(s) (if applicable)

The attached publication has been **superseded by** the following publication(s):

Series/Number	NIST SP 800-63B-4
Title	Digital Identity Guidelines: Authentication and Authenticator Management
Author(s)	David Temoshok, et al.
Publication Date(s)	July 2025
URL/DOI	https://doi.org/10.6028/NIST.SP.800-63B-4

Additional Information (if applicable)

Contact	Applied Cybersecurity Division (Information Technology Laboratory)
Latest revision of the attached publication	
Related Information	https://csrc.nist.gov/pubs/sp/800/63/b/4/final https://www.nist.gov/identity-access-management/nist-special-publication-800-63-digital-identity-guidelines
Withdrawal Announcement Link	

NIST Special Publication 800-63B

Digital Identity Guidelines

Authentication and Lifecycle Management

Paul A. Grassi
James L. Fenton
Elaine M. Newton
Ray A. Perlner
Andrew R. Regenscheid
William E. Burr
Justin P. Richer

Privacy Authors:
Naomi B. Lefkowitz
Jamie M. Danker

Usability Authors:
Yee-Yin Choong
Kristen K. Greene
Mary F. Theofanos

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-63b>

NIST Special Publication 800-63B

Digital Identity Guidelines

Authentication and Lifecycle Management

Paul A. Grassi
Elaine M. Newton
*Applied Cybersecurity Division
Information Technology Laboratory*

James L. Fenton
*Altmode Networks
Los Altos, Calif.*

Privacy Authors:
Naomi B. Lefkowitz
*Applied Cybersecurity Division
Information Technology Laboratory*

Jamie M. Danker
*National Protection and Programs Directorate
Department of Homeland Security*

Ray A. Perlner
Andrew R. Regenscheid
*Computer Security Division
Information Technology Laboratory*

William E. Burr
*Dakota Consulting, Inc.
Silver Spring, Md.*

Justin P. Richer
*Bespoke Engineering
Billerica, Mass.*

Usability Authors:
Yee-Yin Choong
Kristen K. Greene
*Information Access Division
Information Technology Laboratory*

Mary F. Theofanos
*Office of Data and Informatics
Material Measurement Laboratory*

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-63b>

June 2017
INCLUDES UPDATES AS OF 03-02-2020; PAGE VIII



U.S. Department of Commerce
Wilbur L. Ross, Jr., Secretary

National Institute of Standards and Technology
Kent Rochford, Acting NIST Director and Under Secretary of Commerce for Standards and Technology

Authority

This publication has been developed by NIST in accordance with its statutory responsibilities under the Federal Information Security Modernization Act (FISMA) of 2014, 44 U.S.C. § 3551 et seq., Public Law (P.L.) 113-283. NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal systems, but such standards and guidelines shall not apply to national security systems without the express approval of appropriate federal officials exercising policy authority over such systems. This guideline is consistent with the requirements of the Office of Management and Budget (OMB) Circular A-130.

Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority. Nor should these guidelines be interpreted as altering or superseding the existing authorities of the Secretary of Commerce, Director of the OMB, or any other federal official. This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.

National Institute of Standards and Technology Special Publication 800-63B
Natl. Inst. Stand. Technol. Spec. Publ. 800-63B, 79 pages (June 2017)
CODEN: NSPUE2

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-63b>

Certain commercial entities, equipment, or materials may be identified in this document in order to describe an experimental procedure or concept adequately. Such identification is not intended to imply recommendation or endorsement by NIST, nor is it intended to imply that the entities, materials, or equipment are necessarily the best available for the purpose.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST.

Organizations are encouraged to review all draft publications during public comment periods and provide feedback to NIST. Many NIST cybersecurity publications, other than the ones noted above, are available at <http://csrc.nist.gov/publications>.

Comments on this publication may be submitted to:

National Institute of Standards and Technology
Attn: Applied Cybersecurity Division, Information Technology Laboratory
100 Bureau Drive (Mail Stop 2000) Gaithersburg, MD 20899-2000
Email: dig-comments@nist.gov

All comments are subject to release under the Freedom of Information Act (FOIA).

Reports on Computer Systems Technology

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations.

Abstract

These guidelines provide technical requirements for federal agencies implementing digital identity services and are not intended to constrain the development or use of standards outside of this purpose. These guidelines focus on the authentication of subjects interacting with government systems over open networks, establishing that a given claimant is a subscriber who has been previously authenticated. The result of the authentication process may be used locally by the system performing the authentication or may be asserted elsewhere in a federated identity system. This document defines technical requirements for each of the three authenticator assurance levels. This publication supersedes corresponding sections of NIST Special Publication (SP) 800-63-2.

Keywords

authentication; credential service provider; digital authentication; digital credentials; electronic authentication; electronic credentials, federation.

Acknowledgments

The authors gratefully acknowledge Kaitlin Boeckl for her artistic graphics contributions to all volumes in the SP 800-63 suite and the contributions of our many reviewers, including Joni Brennan from the Digital ID & Authentication Council of Canada (DIACC), Kat Megas, Ellen Nadeau, and Ben Piccarreta from NIST, and Ryan Galluzzo and Danna Gabel O'Rourke from Deloitte & Touche LLP.

The authors would also like to acknowledge the thought leadership and innovation of the original authors: Donna F. Dodson, W. Timothy Polk, Sarbari Gupta, and Emad A. Nabbus. Without their tireless efforts, we would not have had the incredible baseline from which to evolve 800-63 to the document it is today. In addition, special thanks to the Federal Privacy Council's Digital Authentication Task Force for the contributions to the development of privacy requirements and considerations.

Requirements Notation and Conventions

The terms "SHALL" and "SHALL NOT" indicate requirements to be followed strictly in order to conform to the publication and from which no deviation is permitted.

The terms "SHOULD" and "SHOULD NOT" indicate that among several possibilities one is recommended as particularly suitable, without mentioning or excluding others, or that a certain course of action is preferred but not necessarily required, or that (in the negative form) a certain possibility or course of action is discouraged but not prohibited.

The terms "MAY" and "NEED NOT" indicate a course of action permissible within the limits of the publication.

The terms "CAN" and "CANNOT" indicate a possibility or capability, whether material, physical or causal or, in the negative, the absence of that possibility or capability.

Table of Contents

1	Purpose.....	1
2	Introduction	2
3	Definitions and Abbreviations	4
4	Authenticator Assurance Levels	5
4.1	Authenticator Assurance Level 1	5
4.1.1	Permitted Authenticator Types	5
4.1.2	Authenticator and Verifier Requirements.....	6
4.1.3	Reauthentication.....	6
4.1.4	Security Controls	6
4.1.5	Records Retention Policy	6
4.2	Authenticator Assurance Level 2	6
4.2.1	Permitted Authenticator Types	7
4.2.2	Authenticator and Verifier Requirements.....	7
4.2.3	Reauthentication.....	8
4.2.4	Security Controls	8
4.2.5	Records Retention Policy	8
4.3	Authenticator Assurance Level 3	8
4.3.1	Permitted Authenticator Types	9
4.3.2	Authenticator and Verifier Requirements.....	9
4.3.3	Reauthentication.....	10
4.3.4	Security Controls	10
4.3.5	Records Retention Policy	10
4.4	Privacy Requirements.....	10
4.5	Summary of Requirements	11
5	Authenticator and Verifier Requirements	13
5.1	Requirements by Authenticator Type.....	13
5.1.1	Memorized Secrets.....	13
5.1.2	Look-Up Secrets.....	15
5.1.3	Out-of-Band Devices	16
5.1.4	Single-Factor OTP Device.....	19
5.1.5	Multi-Factor OTP Devices	20
5.1.6	Single-Factor Cryptographic Software.....	22

5.1.7	Single-Factor Cryptographic Devices	22
5.1.8	Multi-Factor Cryptographic Software	23
5.1.9	Multi-Factor Cryptographic Devices.....	24
5.2	General Authenticator Requirements.....	25
5.2.1	Physical Authenticators	25
5.2.2	Rate Limiting (Throttling)	25
5.2.3	Use of Biometrics	26
5.2.4	Attestation	28
5.2.5	Verifier Impersonation Resistance.....	28
5.2.6	Verifier-CSP Communications.....	29
5.2.7	Verifier-Compromise Resistance.....	29
5.2.8	Replay Resistance.....	30
5.2.9	Authentication Intent.....	30
5.2.10	Restricted Authenticators	30
6	Authenticator Lifecycle Management.....	32
6.1	Authenticator Binding.....	32
6.1.1	Binding at Enrollment	33
6.1.2	Post-Enrollment Binding	34
6.1.3	Binding to a Subscriber-provided Authenticator	35
6.1.4	Renewal	35
6.2	Loss, Theft, Damage, and Unauthorized Duplication.....	35
6.3	Expiration.....	36
6.4	Revocation and Termination	36
7	Session Management	37
7.1	Session Bindings	37
7.1.1	Browser Cookies	38
7.1.2	Access Tokens	38
7.1.3	Device Identification	38
7.2	Reauthentication	39
7.2.1	Reauthentication from a Federation or Assertion	39
8	Threats and Security Considerations.....	41
8.1	Authenticator Threats.....	41
8.2	Threat Mitigation Strategies	45

8.3	Authenticator Recovery.....	47
8.4	Session Attacks	47
9	Privacy Considerations	48
9.1	Privacy Risk Assessment.....	48
9.2	Privacy Controls.....	48
	Processing Limitation.....	48
9.3	48	
9.4	Agency-Specific Privacy Compliance.....	49
10	Usability Considerations	50
10.1	Usability Considerations Common to Authenticators	51
10.2	Usability Considerations by Authenticator Type.....	53
	10.2.1 Memorized Secrets.....	53
	10.2.2 Look-Up Secrets.....	54
	10.2.3 Out-of-Band.....	54
	10.2.4 Single-Factor OTP Device.....	54
	10.2.5 Multi-Factor OTP Device	55
	10.2.6 Single-Factor Cryptographic Software.....	56
	10.2.7 Single-Factor Cryptographic Device	56
	10.2.8 Multi-Factor Cryptographic Software	56
	10.2.9 Multi-Factor Cryptographic Device	57
10.3	Summary of Usability Considerations	57
10.4	Biometrics Usability Considerations.....	59
11	References.....	62
11.1	General References.....	62
11.2	Standards	63
11.3	NIST Special Publications.....	64
11.4	Federal Information Processing Standards.....	65

List of Appendices

Appendix A— Strength of Memorized Secrets	67
A.1 Introduction	67
A.2 Length.....	67
A.3 Complexity	68

A.4 Randomly-Chosen Secrets 69

A.5 Summary 69

List of Tables

Table 2-1 Normative and Informative Sections of SP 800-63B 3

Table 4-1 AAL Summary of Requirements..... 11

Table 8-1 Authenticator Threats 41

Table 8-2 Mitigating Authenticator Threats..... 45

Errata

This table contains changes that have been incorporated into Special Publication 800-63B. Errata updates can include corrections, clarifications, or other minor changes in the publication that are either editorial or substantive in nature.

Date	Type	Change	Location
2017-12-01	Editorial	Updated AAL descriptions for consistency with other text in document	Introduction
	Editorial	Deleted “cryptographic” to consistently reflect authenticator options at AAL3	§4.3
	Substantive	Refined the requirements about processing of attributes	§4.4
	Editorial	Make language regarding activation factors for multifactor authenticators consistent	§5.1.5.1, 5.1.8.1, and 5.1.9.1
	Substantive	Recognize use of hardware TPM as hardware crypto authenticator	§5.1.7.1, 5.1.9.1
	Editorial	Improve normative language on authenticated protected channels for biometrics	§5.2.3
	Editorial	Changed “transaction” to “binding transaction” to emphasize that requirement doesn’t apply to authentication transactions	§6.1.1
	Editorial	Replaced out-of-context note at end of section 7.2	§7.2
	Editorial	Changed IdP to CSP to match terminology used elsewhere in this document	Table 8-1
	Editorial	Corrected capitalization of Side Channel Attack	Table 8-2
	Substantive	Changed the title to processing limitation; clarified the language, incorporated privacy objectives language, and specified that consent is explicit	§9.3
	Editorial	Added NISTIR 8062 as a reference	§11.1
	Editorial	Corrected title of SP 800-63C	§11.3
2020-03-02	Substantive	Clarified wording of verifier impersonation resistance requirement	§4.3.2
	Editorial	Emphasized use of key unlocked by additional factor to sign nonce	§5.1.9.1
	Editorial	Provided examples of risk-based behavior observations	§5.2.2
	Editorial	Removed redundant phrase and added missing conjunction	§5.2.3
	Editorial	Updated URL for reference [Blacklists]	§11.1

1 Purpose

This section is informative.

This document and its companion documents, [Special Publication \(SP\) 800-63](#), [SP 800-63A](#), and [SP 800-63C](#), provide technical guidelines to agencies for the implementation of digital authentication.

2 Introduction

This section is informative.

Digital identity is the unique representation of a subject engaged in an online transaction. A digital identity is always unique in the context of a digital service, but does not necessarily need to be traceable back to a specific real-life subject. In other words, accessing a digital service may not mean that the underlying subject's real-life representation is known. Identity proofing establishes that a subject is actually who they claim to be. Digital authentication is the process of determining the validity of one or more authenticators used to claim a digital identity.

Authentication establishes that a subject attempting to access a digital service is in control of the technologies used to authenticate. For services in which return visits are applicable, successfully authenticating provides reasonable risk-based assurances that the subject accessing the service today is the same as the one who accessed the service previously. Digital identity presents a technical challenge because it often involves the proofing of individuals over an open network and always involves the authentication of individuals over an open network. This presents multiple opportunities for impersonation and other attacks which can lead to fraudulent claims of a subject's digital identity.

The ongoing authentication of subscribers is central to the process of associating a subscriber with their online activity. Subscriber authentication is performed by verifying that the claimant controls one or more *authenticators* (called *tokens* in earlier versions of SP 800-63) associated with a given subscriber. A successful authentication results in the assertion of an identifier, either pseudonymous or non-pseudonymous, and optionally other identity information, to the relying party (RP).

This document provides recommendations on types of authentication processes, including choices of authenticators, that may be used at various *Authenticator Assurance Levels* (AALs). It also provides recommendations on the lifecycle of authenticators, including revocation in the event of loss or theft.

This technical guideline applies to digital authentication of subjects to systems over a network. It does not address the authentication of a person for physical access (e.g., to a building), though some credentials used for digital access may also be used for physical access authentication. This technical guideline also requires that federal systems and service providers participating in authentication protocols be authenticated to subscribers.

The strength of an authentication transaction is characterized by an ordinal measurement known as the AAL. Stronger authentication (a higher AAL) requires malicious actors to have better capabilities and expend greater resources in order to successfully subvert the authentication process. Authentication at higher AALs can effectively reduce the risk of attacks. A high-level summary of the technical requirements for each of the AALs is provided below; see [Sections 4 and 5](#) of this document for specific normative requirements.

Authenticator Assurance Level 1: AAL1 provides some assurance that the claimant controls an authenticator bound to the subscriber's account. AAL1 requires either single-factor or multi-factor authentication using a wide range of available authentication technologies. Successful

authentication requires that the claimant prove possession and control of the authenticator through a secure authentication protocol.

Authenticator Assurance Level 2: AAL2 provides high confidence that the claimant controls authenticator(s) bound to the subscriber's account. Proof of possession and control of two different authentication factors is required through secure authentication protocol(s). Approved cryptographic techniques are required at AAL2 and above.

Authenticator Assurance Level 3: AAL3 provides very high confidence that the claimant controls authenticator(s) bound to the subscriber's account. Authentication at AAL3 is based on proof of possession of a key through a cryptographic protocol. AAL3 authentication requires a hardware-based authenticator and an authenticator that provides verifier impersonation resistance; the same device may fulfill both these requirements. In order to authenticate at AAL3, claimants are required to prove possession and control of two distinct authentication factors through secure authentication protocol(s). Approved cryptographic techniques are required.

The following table states which sections of the document are normative and which are informative:

Table 2-1 Normative and Informative Sections of SP 800-63B

Section Name	Normative/Informative
1. Purpose	Informative
2. Introduction	Informative
3. Definitions and Abbreviations	Informative
4. Authenticator Assurance Levels	Normative
5. Authenticator and Verifier Requirements	Normative
6. Authenticator Lifecycle Management	Normative
7. Session Management	Normative
8. Threat and Security Considerations	Informative
9. Privacy Considerations	Informative
10. Usability Considerations	Informative
11. References	Informative
Appendix A — Strength of Memorized Secrets	Informative

3 Definitions and Abbreviations

See [SP 800-63](#), Appendix A for a complete set of definitions and abbreviations.

4 Authenticator Assurance Levels

This section contains both normative and informative material.

To satisfy the requirements of a given AAL, a claimant SHALL be authenticated with at least a given level of strength to be recognized as a subscriber. The result of an authentication process is an identifier that SHALL be used each time that subscriber authenticates to that RP. The identifier MAY be pseudonymous. Subscriber identifiers SHOULD NOT be reused for a different subject but SHOULD be reused when a previously-enrolled subject is re-enrolled by the CSP. Other attributes that identify the subscriber as a unique subject MAY also be provided.

Detailed normative requirements for authenticators and verifiers at each AAL are provided in Section 5.

See [SP 800-63](#) Section 6.2 for details on how to choose the most appropriate AAL.

FIPS 140 requirements are satisfied by [FIPS 140-2](#) or newer revisions.

At IAL1, it is possible that attributes are collected and made available by the digital identity service. Any PII or other personal information — whether self-asserted or validated — requires multi-factor authentication. Therefore, agencies SHALL select a minimum of AAL2 when self-asserted PII or other personal information is made available online.

4.1 Authenticator Assurance Level 1

This section is normative.

AAL1 provides some assurance that the claimant controls an authenticator bound to the subscriber's account. AAL1 requires either single-factor or multi-factor authentication using a wide range of available authentication technologies. Successful authentication requires that the claimant prove possession and control of the authenticator through a secure authentication protocol.

4.1.1 Permitted Authenticator Types

AAL1 authentication SHALL occur by the use of any of the following authenticator types, which are defined in [Section 5](#):

- Memorized Secret ([Section 5.1.1](#))
- Look-Up Secret ([Section 5.1.2](#))
- Out-of-Band Devices ([Section 5.1.3](#))
- Single-Factor One-Time Password (OTP) Device ([Section 5.1.4](#))
- Multi-Factor OTP Device ([Section 5.1.5](#))
- Single-Factor Cryptographic Software ([Section 5.1.6](#))
- Single-Factor Cryptographic Device ([Section 5.1.7](#))
- Multi-Factor Cryptographic Software ([Section 5.1.8](#))
- Multi-Factor Cryptographic Device ([Section 5.1.9](#))

4.1.2 Authenticator and Verifier Requirements

Cryptographic authenticators used at AAL1 SHALL use approved cryptography. Software-based authenticators that operate within the context of an operating system MAY, where applicable, attempt to detect compromise (e.g., by malware) of the user endpoint in which they are running and SHOULD NOT complete the operation when such a compromise is detected.

Communication between the claimant and verifier (using the primary channel in the case of an out-of-band authenticator) SHALL be via an authenticated protected channel to provide confidentiality of the authenticator output and resistance to man-in-the-middle (MitM) attacks.

Verifiers operated by government agencies at AAL1 SHALL be validated to meet the requirements of [FIPS 140](#) Level 1.

4.1.3 Reauthentication

Periodic reauthentication of subscriber sessions SHALL be performed as described in [Section 7.2](#). At AAL1, reauthentication of the subscriber SHOULD be repeated at least once per 30 days during an extended usage session, regardless of user activity. The session SHOULD be terminated (i.e., logged out) when this time limit is reached.

4.1.4 Security Controls

The CSP SHALL employ appropriately-tailored security controls from the *low* baseline of security controls defined in [SP 800-53](#) or equivalent federal (e.g., [FEDRAMP](#)) or industry standard. The CSP SHALL ensure that the minimum assurance-related controls for *low-impact* systems, or equivalent, are satisfied.

4.1.5 Records Retention Policy

The CSP shall comply with its respective records retention policies in accordance with applicable laws, regulations, and policies, including any National Archives and Records Administration (NARA) records retention schedules that may apply. If the CSP opts to retain records in the absence of any mandatory requirements, the CSP SHALL conduct a risk management process, including assessments of privacy and security risks, to determine how long records should be retained and SHALL inform the subscriber of that retention policy.

4.2 Authenticator Assurance Level 2

This section is normative.

AAL2 provides high confidence that the claimant controls authenticator(s) bound to the subscriber's account. Proof of possession and control of two distinct authentication factors is required through secure authentication protocol(s). Approved cryptographic techniques are required at AAL2 and above.

4.2.1 Permitted Authenticator Types

At AAL2, authentication SHALL occur by the use of either a multi-factor authenticator or a combination of two single-factor authenticators. A multi-factor authenticator requires two factors to execute a single authentication event, such as a cryptographically-secure device with an integrated biometric sensor that is required to activate the device. Authenticator requirements are specified in [Section 5](#).

When a multi-factor authenticator is used, any of the following MAY be used:

- Multi-Factor OTP Device ([Section 5.1.5](#))
- Multi-Factor Cryptographic Software ([Section 5.1.8](#))
- Multi-Factor Cryptographic Device ([Section 5.1.9](#))

When a combination of two single-factor authenticators is used, it SHALL include a Memorized Secret authenticator ([Section 5.1.1](#)) and one possession-based (i.e., “something you have”) authenticator from the following list:

- Look-Up Secret ([Section 5.1.2](#))
- Out-of-Band Device ([Section 5.1.3](#))
- Single-Factor OTP Device ([Section 5.1.4](#))
- Single-Factor Cryptographic Software ([Section 5.1.6](#))
- Single-Factor Cryptographic Device ([Section 5.1.7](#))

Note: When biometric authentication meets the requirements in [Section 5.2.3](#), the device has to be authenticated in addition to the biometric — a biometric is recognized as a factor, but not recognized as an authenticator by itself. Therefore, when conducting authentication with a biometric, it is unnecessary to use two authenticators because the associated device serves as “something you have,” while the biometric serves as “something you are.”

4.2.2 Authenticator and Verifier Requirements

Cryptographic authenticators used at AAL2 SHALL use approved cryptography. Authenticators procured by government agencies SHALL be validated to meet the requirements of [FIPS 140](#) Level 1. Software-based authenticators that operate within the context of an operating system MAY, where applicable, attempt to detect compromise of the platform in which they are running (e.g., by malware) and SHOULD NOT complete the operation when such a compromise is detected. At least one authenticator used at AAL2 SHALL be replay resistant as described in [Section 5.2.8](#). Authentication at AAL2 SHOULD demonstrate authentication intent from at least one authenticator as discussed in [Section 5.2.9](#).

Communication between the claimant and verifier (the primary channel in the case of an out-of-band authenticator) SHALL be via an authenticated protected channel to provide confidentiality of the authenticator output and resistance to MitM attacks.

Verifiers operated by government agencies at AAL2 SHALL be validated to meet the requirements of [FIPS 140](#) Level 1.

When a device such as a smartphone is used in the authentication process, the unlocking of that device (typically done using a PIN or biometric) SHALL NOT be considered one of the authentication factors. Generally, it is not possible for a verifier to know that the device had been locked or if the unlock process met the requirements for the relevant authenticator type.

When a biometric factor is used in authentication at AAL2, the performance requirements stated in [Section 5.2.3](#) SHALL be met, and the verifier SHOULD make a determination that the biometric sensor and subsequent processing meet these requirements.

4.2.3 Reauthentication

Periodic reauthentication of subscriber sessions SHALL be performed as described in [Section 7.2](#). At AAL2, authentication of the subscriber SHALL be repeated at least once per 12 hours during an extended usage session, regardless of user activity. Reauthentication of the subscriber SHALL be repeated following any period of inactivity lasting 30 minutes or longer. The session SHALL be terminated (i.e., logged out) when either of these time limits is reached.

Reauthentication of a session that has not yet reached its time limit MAY require only a memorized secret or a biometric in conjunction with the still-valid session secret. The verifier MAY prompt the user to cause activity just before the inactivity timeout.

4.2.4 Security Controls

The CSP SHALL employ appropriately-tailored security controls from the *moderate* baseline of security controls defined in [SP 800-53](#) or equivalent federal (e.g., [FEDRAMP](#)) or industry standard. The CSP SHALL ensure that the minimum assurance-related controls for *moderate-impact* systems or equivalent are satisfied.

4.2.5 Records Retention Policy

The CSP shall comply with its respective records retention policies in accordance with applicable laws, regulations, and policies, including any NARA records retention schedules that may apply. If the CSP opts to retain records in the absence of any mandatory requirements, the CSP SHALL conduct a risk management process, including assessments of privacy and security risks to determine how long records should be retained and SHALL inform the subscriber of that retention policy.

4.3 Authenticator Assurance Level 3

This section is normative.

AAL3 provides very high confidence that the claimant controls authenticator(s) bound to the subscriber's account. Authentication at AAL3 is based on proof of possession of a key through a cryptographic protocol. AAL3 authentication SHALL use a hardware-based authenticator and an authenticator that provides verifier impersonation resistance — the same device MAY fulfill both these requirements. In order to authenticate at AAL3, claimants SHALL prove possession and control of two distinct authentication factors through secure authentication protocol(s). Approved cryptographic techniques are required.

4.3.1 Permitted Authenticator Types

AAL3 authentication SHALL occur by the use of one of a combination of authenticators satisfying the requirements in Section 4.3. Possible combinations are:

- Multi-Factor Cryptographic Device ([Section 5.1.9](#))
- Single-Factor Cryptographic Device ([Section 5.1.7](#)) used in conjunction with Memorized Secret ([Section 5.1.1](#))
- Multi-Factor OTP device (software or hardware) ([Section 5.1.5](#)) used in conjunction with a Single-Factor Cryptographic Device ([Section 5.1.7](#))
- Multi-Factor OTP Device (hardware only) ([Section 5.1.5](#)) used in conjunction with a Single-Factor Cryptographic Software ([Section 5.1.6](#))
- Single-Factor OTP Device (hardware only) ([Section 5.1.4](#)) used in conjunction with a Multi-Factor Cryptographic Software Authenticator ([Section 5.1.8](#))
- Single-Factor OTP Device (hardware only) ([Section 5.1.4](#)) used in conjunction with a Single-Factor Cryptographic Software Authenticator ([Section 5.1.6](#)) and a Memorized Secret ([Section 5.1.1](#))

4.3.2 Authenticator and Verifier Requirements

Communication between the claimant and verifier SHALL be via an authenticated protected channel to provide confidentiality of the authenticator output and resistance to MitM attacks. At least one cryptographic device authenticator used at AAL3 SHALL be verifier impersonation resistant as described in [Section 5.2.5](#) and SHALL be replay resistant as described in [Section 5.2.8](#). All authentication and reauthentication processes at AAL3 SHALL demonstrate authentication intent from at least one authenticator as described in [Section 5.2.9](#).

Multi-factor authenticators used at AAL3 SHALL be hardware cryptographic modules validated at [FIPS 140](#) Level 2 or higher overall with at least [FIPS 140](#) Level 3 physical security. Single-factor cryptographic devices used at AAL3 SHALL be validated at [FIPS 140](#) Level 1 or higher overall with at least [FIPS 140](#) Level 3 physical security.

Verifiers at AAL3 SHALL be validated at [FIPS 140](#) Level 1 or higher.

Verifiers at AAL3 SHALL be verifier compromise resistant as described in [Section 5.2.7](#) with respect to at least one authentication factor.

Hardware-based authenticators and verifiers at AAL3 SHOULD resist relevant side-channel (e.g., timing and power-consumption analysis) attacks. Relevant side-channel attacks SHALL be determined by a risk assessment performed by the CSP.

When a device such a smartphone is used in the authentication process — presuming that the device is able to meet the requirements above — the unlocking of that device SHALL NOT be considered to satisfy one of the authentication factors. This is because it is generally not possible for verifier to know that the device had been locked nor whether the unlock process met the requirements for the relevant authenticator type.

When a biometric factor is used in authentication at AAL3, the verifier SHALL make a determination that the biometric sensor and subsequent processing meet the performance requirements stated in [Section 5.2.3](#).

4.3.3 Reauthentication

Periodic reauthentication of subscriber sessions SHALL be performed as described in [Section 7.2](#). At AAL3, authentication of the subscriber SHALL be repeated at least once per 12 hours during an extended usage session, regardless of user activity, as described in [Section 7.2](#). Reauthentication of the subscriber SHALL be repeated following any period of inactivity lasting 15 minutes or longer. Reauthentication SHALL use both authentication factors. The session SHALL be terminated (i.e., logged out) when either of these time limits is reached. The verifier MAY prompt the user to cause activity just before the inactivity timeout.

4.3.4 Security Controls

The CSP SHALL employ appropriately-tailored security controls from the *high* baseline of security controls defined in [SP 800-53](#) or an equivalent federal (e.g., [FEDRAMP](#)) or industry standard. The CSP SHALL ensure that the minimum assurance-related controls for *high-impact* systems or equivalent are satisfied.

4.3.5 Records Retention Policy

The CSP shall comply with its respective records retention policies in accordance with applicable laws, regulations, and policies, including any NARA records retention schedules that may apply. If the CSP opts to retain records in the absence of any mandatory requirements, the CSP SHALL conduct a risk management process, including assessments of privacy and security risks, to determine how long records should be retained and SHALL inform the subscriber of that retention policy.

4.4 Privacy Requirements

This section is normative.

The CSP SHALL employ appropriately-tailored privacy controls defined in [SP 800-53](#) or equivalent industry standard.

If CSPs process attributes for purposes other than identity proofing, authentication, or attribute assertion (collectively “identity service”), related fraud mitigation, or to comply with law or legal process, CSPs SHALL implement measures to maintain predictability and manageability commensurate with the privacy risk arising from the additional processing. Measures MAY include providing clear notice, obtaining subscriber consent, or enabling selective use or disclosure of attributes. When CSPs use consent measures, CSPs SHALL NOT make consent for the additional processing a condition of the identity service.

Regardless of whether the CSP is an agency or private sector provider, the following requirements apply to an agency offering or using the authentication service:

- The agency SHALL consult with their Senior Agency Official for Privacy (SAOP) and conduct an analysis to determine whether the collection of PII to issue or maintain authenticators triggers the requirements of the *Privacy Act of 1974* [[Privacy Act](#)] (see [Section 9.4](#)).
 - The agency SHALL publish a System of Records Notice (SORN) to cover such collections, as applicable.
 - The agency SHALL consult with their SAOP and conduct an analysis to determine whether the collection of PII to issue or maintain authenticators triggers the requirements of the *E-Government Act of 2002* [[EGov](#)].
 - The agency SHALL publish a Privacy Impact Assessment (PIA) to cover such collection, as applicable.

4.5 Summary of Requirements

This section is informative.

Table 4-1 summarizes the requirements for each of the AALs:

Table 4-1 AAL Summary of Requirements

Requirement	AAL1	AAL2	AAL3
Permitted Authenticator Types	Memorized Secret; Look-Up Secret; Out-of-Band; SF OTP Device; MF OTP Device; SF Crypto Software; SF Crypto Device; MF Crypto Software; MF Crypto Device	MF OTP Device; MF Crypto Software; MF Crypto Device; or Memorized Secret plus: • Look-Up Secret • Out-of-Band • SF OTP Device • SF Crypto Software • SF Crypto Device	MF Crypto Device; SF Crypto Device plus Memorized Secret; SF OTP Device plus MF Crypto Device or Software; SF OTP Device plus SF Crypto Software plus Memorized Secret
FIPS 140 Verification	Level 1 (Government agency verifiers)	Level 1 (Government agency authenticators and verifiers)	Level 2 overall (MF authenticators) Level 1 overall (verifiers and SF Crypto Devices) Level 3 physical security (all authenticators)
Reauthentication	30 days	12 hours or 30 minutes inactivity; MAY use one authentication factor	12 hours or 15 minutes inactivity; SHALL use both authentication factors

Requirement	AAL1	AAL2	AAL3
Security Controls	SP 800-53 Low Baseline (or equivalent)	SP 800-53 Moderate Baseline (or equivalent)	SP 800-53 High Baseline (or equivalent)
MitM Resistance	Required	Required	Required
Verifier-Impersonation Resistance	Not required	Not required	Required
Verifier-Compromise Resistance	Not required	Not required	Required
Replay Resistance	Not required	Not required	Required
Authentication Intent	Not required	Recommended	Required
Records Retention Policy	Required	Required	Required
Privacy Controls	Required	Required	Required

5 Authenticator and Verifier Requirements

This section is normative.

This section provides the detailed requirements specific to each type of authenticator. With the exception of reauthentication requirements specified in [Section 4](#) and the requirement for verifier impersonation resistance at AAL3 described in [Section 5.2.5](#), the technical requirements for each of the authenticator types are the same regardless of the AAL at which the authenticator is used.

5.1 Requirements by Authenticator Type

5.1.1 Memorized Secrets



A Memorized Secret authenticator — commonly referred to as a *password* or, if numeric, a *PIN* — is a secret value intended to be chosen and memorized by the user. Memorized secrets need to be of sufficient complexity and secrecy that it would be impractical for an attacker to guess or otherwise discover the correct secret value. A memorized secret is *something you know*.

5.1.1.1 Memorized Secret Authenticators

Memorized secrets SHALL be at least 8 characters in length if chosen by the subscriber. Memorized secrets chosen randomly by the CSP or verifier SHALL be at least 6 characters in length and MAY be entirely numeric. If the CSP or verifier disallows a chosen memorized secret based on its appearance on a blacklist of compromised values, the subscriber SHALL be required to choose a different memorized secret. No other complexity requirements for memorized secrets SHOULD be imposed. A rationale for this is presented in [Appendix A](#) *Strength of Memorized Secrets*.

5.1.1.2 Memorized Secret Verifiers

Verifiers SHALL require subscriber-chosen memorized secrets to be at least 8 characters in length. Verifiers SHOULD permit subscriber-chosen memorized secrets at least 64 characters in length. All printing ASCII [\[RFC 20\]](#) characters as well as the space character SHOULD be acceptable in memorized secrets. Unicode [\[ISO/ISC 10646\]](#) characters SHOULD be accepted as well. To make allowances for likely mistyping, verifiers MAY replace multiple consecutive space characters with a single space character prior to verification, provided that the result is at least 8 characters in length. Truncation of the secret SHALL NOT be performed. For purposes of the above length requirements, each Unicode code point SHALL be counted as a single character.

If Unicode characters are accepted in memorized secrets, the verifier SHOULD apply the Normalization Process for Stabilized Strings using either the NFKC or NFKD normalization defined in Section 12.1 of Unicode Standard Annex 15 [\[UAX 15\]](#). This process is applied before hashing the byte string representing the memorized secret. Subscribers choosing memorized secrets containing Unicode characters SHOULD be advised that some characters may be represented differently by some endpoints, which can affect their ability to authenticate successfully.

Memorized secrets that are randomly chosen by the CSP (e.g., at enrollment) or by the verifier (e.g., when a user requests a new PIN) SHALL be at least 6 characters in length and SHALL be generated using an approved random bit generator [[SP 800-90Ar1](#)].

Memorized secret verifiers SHALL NOT permit the subscriber to store a “hint” that is accessible to an unauthenticated claimant. Verifiers SHALL NOT prompt subscribers to use specific types of information (e.g., “What was the name of your first pet?”) when choosing memorized secrets.

When processing requests to establish and change memorized secrets, verifiers SHALL compare the prospective secrets against a list that contains values known to be commonly-used, expected, or compromised. For example, the list MAY include, but is not limited to:

- Passwords obtained from previous breach corpuses.
- Dictionary words.
- Repetitive or sequential characters (e.g. ‘aaaaaa’, ‘1234abcd’).
- Context-specific words, such as the name of the service, the username, and derivatives thereof.

If the chosen secret is found in the list, the CSP or verifier SHALL advise the subscriber that they need to select a different secret, SHALL provide the reason for rejection, and SHALL require the subscriber to choose a different value.

Verifiers SHOULD offer guidance to the subscriber, such as a password-strength meter [[Meters](#)], to assist the user in choosing a strong memorized secret. This is particularly important following the rejection of a memorized secret on the above list as it discourages trivial modification of listed (and likely very weak) memorized secrets [[Blacklists](#)].

Verifiers SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber’s account as described in [Section 5.2.2](#).

Verifiers SHOULD NOT impose other composition rules (e.g., requiring mixtures of different character types or prohibiting consecutively repeated characters) for memorized secrets. Verifiers SHOULD NOT require memorized secrets to be changed arbitrarily (e.g., periodically). However, verifiers SHALL force a change if there is evidence of compromise of the authenticator.

Verifiers SHOULD permit claimants to use “paste” functionality when entering a memorized secret. This facilitates the use of password managers, which are widely used and in many cases increase the likelihood that users will choose stronger memorized secrets.

In order to assist the claimant in successfully entering a memorized secret, the verifier SHOULD offer an option to display the secret — rather than a series of dots or asterisks — until it is entered. This allows the claimant to verify their entry if they are in a location where their screen is unlikely to be observed. The verifier MAY also permit the user’s device to display individual entered characters for a short time after each character is typed to verify correct entry. This is particularly applicable on mobile devices.

The verifier SHALL use approved encryption and an authenticated protected channel when requesting memorized secrets in order to provide resistance to eavesdropping and MitM attacks.

Verifiers SHALL store memorized secrets in a form that is resistant to offline attacks. Memorized secrets SHALL be salted and hashed using a suitable one-way key derivation function. Key derivation functions take a password, a salt, and a cost factor as inputs then generate a password hash. Their purpose is to make each password guessing trial by an attacker who has obtained a password hash file expensive and therefore the cost of a guessing attack high or prohibitive. Examples of suitable key derivation functions include Password-based Key Derivation Function 2 (PBKDF2) [SP 800-132] and Balloon [BALLOON]. A memory-hard function SHOULD be used because it increases the cost of an attack. The key derivation function SHALL use an approved one-way function such as Keyed Hash Message Authentication Code (HMAC) [FIPS 198-1], any approved hash function in SP 800-107, Secure Hash Algorithm 3 (SHA-3) [FIPS 202], CMAC [SP 800-38B] or Keccak Message Authentication Code (KMAC), Customizable SHAKE (cSHAKE), or ParallelHash [SP 800-185]. The chosen output length of the key derivation function SHOULD be the same as the length of the underlying one-way function output.

The salt SHALL be at least 32 bits in length and be chosen arbitrarily so as to minimize salt value collisions among stored hashes. Both the salt value and the resulting hash SHALL be stored for each subscriber using a memorized secret authenticator.

For PBKDF2, the cost factor is an iteration count: the more times the PBKDF2 function is iterated, the longer it takes to compute the password hash. Therefore, the iteration count SHOULD be as large as verification server performance will allow, typically at least 10,000 iterations.

In addition, verifiers SHOULD perform an additional iteration of a key derivation function using a salt value that is secret and known only to the verifier. This salt value, if used, SHALL be generated by an approved random bit generator [SP 800-90Ar1] and provide at least the minimum security strength specified in the latest revision of SP 800-131A (112 bits as of the date of this publication). The secret salt value SHALL be stored separately from the hashed memorized secrets (e.g., in a specialized device like a hardware security module). With this additional iteration, brute-force attacks on the hashed memorized secrets are impractical as long as the secret salt value remains secret.

5.1.2 Look-Up Secrets



A look-up secret authenticator is a physical or electronic record that stores a set of secrets shared between the claimant and the CSP. The claimant uses the authenticator to look up the appropriate secret(s) needed to respond to a prompt from the verifier. For example, the verifier may ask a claimant to provide a specific subset of the numeric or character strings printed on a card in table format. A common application of look-up secrets is the use of "recovery keys" stored by the subscriber for use in the event another authenticator is lost or malfunctions. A look-up secret is *something you have*.

5.1.2.1 Look-Up Secret Authenticators

CSPs creating look-up secret authenticators SHALL use an approved random bit generator [[SP 800-90Ar1](#)] to generate the list of secrets and SHALL deliver the authenticator securely to the subscriber. Look-up secrets SHALL have at least 20 bits of entropy.

Look-up secrets MAY be distributed by the CSP in person, by postal mail to the subscriber's address of record, or by online distribution. If distributed online, look-up secrets SHALL be distributed over a secure channel in accordance with the post-enrollment binding requirements in [Section 6.1.2](#).

If the authenticator uses look-up secrets sequentially from a list, the subscriber MAY dispose of used secrets, but only after a successful authentication.

5.1.2.2 Look-Up Secret Verifiers

Verifiers of look-up secrets SHALL prompt the claimant for the next secret from their authenticator or for a specific (e.g., numbered) secret. A given secret from an authenticator SHALL be used successfully only once. If the look-up secret is derived from a grid card, each cell of the grid SHALL be used only once.

Verifiers SHALL store look-up secrets in a form that is resistant to offline attacks. Look-up secrets having at least 112 bits of entropy SHALL be hashed with an approved one-way function as described in [Section 5.1.1.2](#). Look-up secrets with fewer than 112 bits of entropy SHALL be salted and hashed using a suitable one-way key derivation function, also described in [Section 5.1.1.2](#). The salt value SHALL be at least 32 in bits in length and arbitrarily chosen so as to minimize salt value collisions among stored hashes. Both the salt value and the resulting hash SHALL be stored for each look-up secret.

For look-up secrets that have less than 64 bits of entropy, the verifier SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber's account as described in [Section 5.2.2](#).

The verifier SHALL use approved encryption and an authenticated protected channel when requesting look-up secrets in order to provide resistance to eavesdropping and MitM attacks.

5.1.3 Out-of-Band Devices



An out-of-band authenticator is a physical device that is uniquely addressable and can communicate securely with the verifier over a distinct communications channel, referred to as the secondary channel. The device is possessed and controlled by the claimant and supports private communication over this secondary channel, separate from the primary channel for e-authentication. An out-of-band authenticator is *something you have*.

The out-of-band authenticator can operate in one of the following ways:

- The claimant transfers a secret received by the out-of-band device via the secondary channel to the verifier using the primary channel. For example, the claimant may receive the secret on their mobile device and type it (typically a 6-digit code) into their authentication session.
- The claimant transfers a secret received via the primary channel to the out-of-band device for transmission to the verifier via the secondary channel. For example, the claimant may view the secret on their authentication session and either type it into an app on their mobile device or use a technology such as a barcode or QR code to effect the transfer.
- The claimant compares secrets received from the primary channel and the secondary channel and confirms the authentication via the secondary channel.

The secret's purpose is to securely bind the authentication operation on the primary and secondary channel. When the response is via the primary communication channel, the secret also establishes the claimant's control of the out-of-band device.

5.1.3.1 Out-of-Band Authenticators

The out-of-band authenticator SHALL establish a separate channel with the verifier in order to retrieve the out-of-band secret or authentication request. This channel is considered to be out-of-band with respect to the primary communication channel (even if it terminates on the same device) provided the device does not leak information from one channel to the other without the authorization of the claimant.

The out-of-band device SHOULD be uniquely addressable and communication over the secondary channel SHALL be encrypted unless sent via the public switched telephone network (PSTN). For additional authenticator requirements specific to the PSTN, see [Section 5.1.3.3](#). Methods that do not prove possession of a specific device, such as voice-over-IP (VOIP) or email, SHALL NOT be used for out-of-band authentication.

The out-of-band authenticator SHALL uniquely authenticate itself in one of the following ways when communicating with the verifier:

- Establish an authenticated protected channel to the verifier using approved cryptography. The key used SHALL be stored in suitably secure storage available to the authenticator application (e.g., keychain storage, TPM, TEE, secure element).
- Authenticate to a public mobile telephone network using a SIM card or equivalent that uniquely identifies the device. This method SHALL only be used if a secret is being sent from the verifier to the out-of-band device via the PSTN (SMS or voice).

If a secret is sent by the verifier to the out-of-band device, the device SHOULD NOT display the authentication secret while it is locked by the owner (i.e., requires an entry of a PIN, passcode, or biometric to view). However, authenticators SHOULD indicate the receipt of an authentication secret on a locked device.

If the out-of-band authenticator sends an approval message over the secondary communication channel — rather than by the claimant transferring a received secret to the primary communication channel — it SHALL do one of the following:

- The authenticator SHALL accept transfer of the secret from the primary channel which it SHALL send to the verifier over the secondary channel to associate the approval with the authentication transaction. The claimant MAY perform the transfer manually or use a technology such as a barcode or QR code to effect the transfer.
- The authenticator SHALL present a secret received via the secondary channel from the verifier and prompt the claimant to verify the consistency of that secret with the primary channel, prior to accepting a yes/no response from the claimant. It SHALL then send that response to the verifier.

5.1.3.2 Out-of-Band Verifiers

For additional verification requirements specific to the PSTN, see [Section 5.1.3.3](#).

If out-of-band verification is to be made using a secure application, such as on a smart phone, the verifier MAY send a push notification to that device. The verifier then waits for the establishment of an authenticated protected channel and verifies the authenticator's identifying key. The verifier SHALL NOT store the identifying key itself, but SHALL use a verification method (e.g., an approved hash function or proof of possession of the identifying key) to uniquely identify the authenticator. Once authenticated, the verifier transmits the authentication secret to the authenticator.

Depending on the type of out-of-band authenticator, one of the following SHALL take place:

- Transfer of secret to primary channel: The verifier MAY signal the device containing the subscriber's authenticator to indicate readiness to authenticate. It SHALL then transmit a random secret to the out-of-band authenticator. The verifier SHALL then wait for the secret to be returned on the primary communication channel.
- Transfer of secret to secondary channel: The verifier SHALL display a random authentication secret to the claimant via the primary channel. It SHALL then wait for the secret to be returned on the secondary channel from the claimant's out-of-band authenticator.
- Verification of secrets by claimant: The verifier SHALL display a random authentication secret to the claimant via the primary channel, and SHALL send the same secret to the out-of-band authenticator via the secondary channel for presentation to the claimant. It SHALL then wait for an approval (or disapproval) message via the secondary channel.

In all cases, the authentication SHALL be considered invalid if not completed within 10 minutes. In order to provide replay resistance as described in [Section 5.2.8](#), verifiers SHALL accept a given authentication secret only once during the validity period.

The verifier SHALL generate random authentication secrets with at least 20 bits of entropy using an approved random bit generator [[SP 800-90Ar1](#)]. If the authentication secret has less than 64 bits of entropy, the verifier SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber's account as described in [Section 5.2.2](#).

5.1.3.3 Authentication using the Public Switched Telephone Network

Use of the PSTN for out-of-band verification is RESTRICTED as described in this section and in [Section 5.2.10](#). If out-of-band verification is to be made using the PSTN, the verifier SHALL verify that the pre-registered telephone number being used is associated with a specific physical device. Changing the pre-registered telephone number is considered to be the binding of a new authenticator and SHALL only occur as described in [Section 6.1.2](#).

Verifiers SHOULD consider risk indicators such as device swap, SIM change, number porting, or other abnormal behavior before using the PSTN to deliver an out-of-band authentication secret.

Note: Consistent with the restriction of authenticators in [Section 5.2.10](#), NIST may adjust the RESTRICTED status of the PSTN over time based on the evolution of the threat landscape and the technical operation of the PSTN.

5.1.4 Single-Factor OTP Device



A single-factor OTP device generates OTPs. This category includes hardware devices and software-based OTP generators installed on devices such as mobile phones. These devices have an embedded secret that is used as the seed for generation of OTPs and does not require activation through a second factor. The OTP is displayed on the device and manually input for transmission to the verifier, thereby proving possession and control of the device. An OTP device may, for example, display 6 characters at a time. A single-factor OTP device is *something you have*.

Single-factor OTP devices are similar to look-up secret authenticators with the exception that the secrets are cryptographically and independently generated by the authenticator and verifier and compared by the verifier. The secret is computed based on a nonce that may be time-based or from a counter on the authenticator and verifier.

5.1.4.1 Single-Factor OTP Authenticators

Single-factor OTP authenticators contain two persistent values. The first is a symmetric key that persists for the device's lifetime. The second is a nonce that is either changed each time the authenticator is used or is based on a real-time clock.

The secret key and its algorithm SHALL provide at least the minimum security strength specified in the latest revision of [SP 800-131A](#) (112 bits as of the date of this publication). The nonce SHALL be of sufficient length to ensure that it is unique for each operation of the device over its lifetime. OTP authenticators — particularly software-based OTP generators — SHOULD discourage and SHALL NOT facilitate the cloning of the secret key onto multiple devices.